

GLOSARIO

1. Ataque de Fuerza Bruta:

Un ataque de fuerza bruta es un procedimiento para averiguar una contraseña que consiste en probar todas las combinaciones posibles hasta encontrar la combinación correcta. Los ataques por fuerza bruta, dado que utilizan el método de prueba y error, tardan mucho tiempo en encontrar la combinación correcta (hablamos en ocasiones de miles años), por esta razón, la fuerza bruta suele combinarse con un ataque de diccionario.

2. Activo de información:

Es cualquier información o sistema relacionado con el tratamiento de la misma que tenga valor para la organización, pueden ser procesos de negocio, datos, aplicaciones, equipos informáticos, personal, soportes de información, redes, equipamiento auxiliar o instalaciones. Es susceptible de ser atacado deliberada o accidentalmente con consecuencias para la organización.

3. Análisis de Riesgos:

Es un proceso que comprende la identificación de activos de información, sus vulnerabilidades y las amenazas a los que se encuentran expuestos, así como la probabilidad de ocurrencia y el impacto de estas, a fin de determinar los controles adecuados para tratar el riesgo.

4. Borrado Seguro:

El borrado seguro es un proceso que asegura la eliminación permanente y segura de la información sensible de un dispositivo de almacenamiento, ya sea un disco duro, una memoria USB o una nube. La importancia de este proceso radica en que, aunque se borre un archivo o una carpeta, la información aún puede ser recuperada por personas malintencionadas con conocimientos en ciberseguridad.

5. Brecha de Seguridad:

Una brecha de seguridad es un incidente que permite el acceso no autorizado a datos informáticos, aplicaciones, redes o dispositivos. Es decir, permite acceder sin autorización a información. Normalmente, se produce cuando un intruso logra sortear los mecanismos de seguridad.

6. Control de acceso:

Definición: Sistema de verificación que permite el acceso a un determinado recurso si la persona o entidad tiene los derechos necesarios para solicitarlo. Este acceso puede ser a recursos de tipo físico (por ejemplo, a un edificio o un departamento) o lógicos (por ejemplo, a un sistema o una aplicación software específica).

7. CSIRT:

Es una unidad aleat encargada de mitigar los daños y restaurar los servicios tras un ciberataque (como malware, phishing, denegación de servicio o brechas de datos). Su enfoque no es solo reactivo (apagar el fuego), sino también proactivo (prevenir que ocurra).

Para que un equipo sea considerado un CSIRT, suele cumplir con estas tres líneas de acción:

- **Respuesta Reactiva:** Análisis de incidentes, manejo de vulnerabilidades y recuperación de sistemas afectados.
- **Actividades Proactivas:** Auditorías de seguridad, difusión de alertas tempranas sobre nuevas amenazas y configuración de sistemas de detección (IDS/IPS).
- **Gestión de la Calidad:** Consultoría técnica, concientización a los usuarios y análisis de riesgos.

8. CVE:

Las vulnerabilidades y exposiciones comunes (CVE) son un conjunto de amenazas de seguridad que se incluyen en un sistema de referencia que describe los riesgos conocidos públicamente.

El objetivo principal es la interoperabilidad. Gracias a los CVE, diferentes herramientas de seguridad (como escáneres de vulnerabilidades, firewalls o sistemas de detección de intrusos) pueden hablar el mismo idioma.

- **Identificación única:** Asegura que dos organizaciones hablen del mismo error técnico.
- **Priorización:** Permite a los administradores de sistemas saber qué parches deben aplicar con urgencia.
- **Historial:** Facilita el rastreo de soluciones y parches oficiales de los fabricantes.

9. CVSS:

El Sistema Común de Puntuación de Vulnerabilidades (CVSS) es un marco abierto para comunicar las características y la gravedad de las vulnerabilidades del software. CVSS consta de tres grupos métricos: Base, Temporal y Ambiental. El grupo base representa las cualidades intrínsecas de una vulnerabilidad que son constantes a lo largo del tiempo y en todos los entornos de usuario, el grupo temporal refleja las características de una vulnerabilidad que cambian con el tiempo y el grupo ambiental representa las características de una vulnerabilidad que son exclusivas del entorno de un usuario. Las métricas base producen una puntuación que va de 0 a 10, que luego puede modificarse puntuando las métricas temporales y ambientales.

10. Denegación de servicio:

Un ataque DDoS (denegación de servicio) tiene como objetivo sitios web y servidores e interrumpe los servicios de red en un intento de agotar los recursos de una aplicación. Los autores de estos ataques desbordan un sitio con tráfico errante, lo que da lugar a una funcionalidad deficiente del sitio web o su desconexión por completo.

Los ataques DDoS tienen gran alcance y se dirigen a todo tipo de sectores y tamaños de empresas de todo el mundo. Determinados sectores, como el de los juegos, el comercio electrónico y las telecomunicaciones, son su blanco más que otros. Los ataques DDoS son algunas de las ciberamenazas más comunes y tienen el potencial de poner en peligro sus negocios, seguridad online, ventas y reputación.

11. DLP:

DLP, o Prevención de Pérdida de Datos, es una solución de ciberseguridad que detecta y previene filtraciones de datos. Como bloquea la extracción de información sensible, las organizaciones la utilizan para la seguridad interna y el cumplimiento normativo.

12. DNS:

El término DNS, del inglés Domain Name Service, se refiere tanto al servicio de Nombres de Dominio, como al servidor que ofrece dicho servicio. El servicio DNS asocia un nombre de dominio con información variada relacionada con ese dominio. Su función más importante es traducir nombres inteligibles para las personas en direcciones IP asociados con los sistemas conectados a la red con el propósito de poder localizar y direccionar estos sistemas de una forma mucho más simple

13. DMZ:

Acronónimo en inglés de Demilitarized Zone; en español, zona desmilitarizada. Consiste en una red aislada que se encuentra dentro de la red interna de la organización. En ella se encuentran ubicados exclusivamente todos los recursos de la empresa que deben ser accesibles desde Internet, como el servidor web o de correo. Por lo general, una DMZ permite las conexiones procedentes tanto de Internet como de la red local de la empresa, donde están los equipos de los trabajadores, pero las conexiones que van desde la DMZ a la red local no están permitidas. Esto se debe a que los servidores que son accesibles desde Internet son más susceptibles a sufrir un ataque que pueda comprometer su seguridad.

14. IPS:

Siglas de Intrusion Prevention System (sistema de prevención de intrusiones). Es un software que se utiliza para proteger a los sistemas de ataques y abusos. La tecnología de prevención de intrusos puede ser considerada como una extensión de los sistemas de detección de intrusos (IDS), pero en realidad es una tecnología más cercana a los cortafuegos.

15. IPSec:

IPSec es un conjunto de reglas o protocolos de comunicación para configurar conexiones seguras a través de una red. El protocolo de Internet (IP) es el estándar común que determina cómo viajan los datos por Internet. IPSec agrega cifrado y autenticación para hacer que el protocolo sea más seguro. Por ejemplo, IPSec codifica los datos en el origen y los decodifica en su destino. También autentica el origen de los datos.

16. Cross Site Scripting (XSS):

Cross-site Scripting (XSS) es una vulnerabilidad de seguridad que normalmente se encuentra en sitios web y/o aplicaciones web que aceptan información del usuario. Algunos ejemplos incluyen motores de búsqueda, formularios de inicio de sesión, tableros de mensajes y cuadros de comentarios.

17. SOC:

Un centro de operaciones de seguridad (SOC) es un centro de comando para monitorear los sistemas de información que una empresa utiliza para su infraestructura de TI. Esto puede incluir todo, desde los sitios web, bases de datos, servidores, aplicaciones, redes, escritorios, centros de datos y una variedad de endpoints de la empresa.

Una configuración de ciberseguridad del SOC monitorea cada elemento de la infraestructura, evalúa su estado actual, incluidas las amenazas potenciales y existentes, y responde a las amenazas. El SOC también establece medidas y protocolos de seguridad de la información diseñados para prevenir amenazas futuras.

18. Sandboxing:

El sandboxing es una práctica de seguridad en la que se utiliza un entorno aislado, o una “caja de arena”, para realizar pruebas. Dentro del sandbox se ejecuta y analiza el código en un entorno seguro y aislado, sin afectar la aplicación, el sistema o la plataforma.

El sandboxing es muy efectivo para defenderse contra amenazas de día cero, que son amenazas que no se habían visto antes o que no coinciden con ningún malware conocido registrado. Aunque los filtros de correo electrónico tradicionales pueden analizar los correos para detectar remitentes maliciosos, tipos de archivos y URL sospechosas, las amenazas de día cero aparecen constantemente y pueden pasar desapercibidas con el filtrado tradicional.

19. Scareware:

Es una táctica de ingeniería social que utiliza mensajes alarmistas (como ventanas emergentes o correos falsos) para asustar al usuario, haciendo creer que su equipo está infectado. Su objetivo es engañar a la persona para que compre software inútil o descargue malware, permitiendo así el robo de datos personales y el fraude de identidad.

20. SIEM:

Es una solución de seguridad que centraliza y analiza los registros (logs) de una organización para detectar amenazas y vulnerabilidades en tiempo real. Evolucionó de la combinación de SIM (gestión de información) y SEM (gestión de eventos), y actualmente utiliza Inteligencia Artificial y análisis de comportamiento (UEBA) para automatizar la respuesta ante incidentes. Es la herramienta principal de los centros de operaciones de seguridad (SOC) para garantizar el cumplimiento normativo.

21. IDS:

Es una herramienta de seguridad que monitorea el tráfico de red en busca de amenazas conocidas o actividades sospechosas. Su función principal es alertar a los equipos de TI ante cualquier anomalía, aunque algunas versiones avanzadas pueden bloquear el tráfico malicioso automáticamente. Puede implementarse como software en hardware local o como una solución especializada en entornos de la nube.

22. Prevención de ejecución de Datos (DEP):

Es una característica de seguridad del sistema operativo que marca regiones de memoria (como la pila o el montón) como no ejecutables. Su función principal es impedir que un atacante ejecute código malicioso aprovechando fallos de memoria, como la saturación del búfer. Si un programa intenta ejecutar código desde una zona protegida, el sistema detiene el proceso para evitar la explotación.

23. Asignación Aleatoria de espacios de direcciones (ASLR):

Es una técnica de seguridad que cambia aleatoriamente la ubicación donde se cargan el código y los datos críticos en la memoria cada vez que se ejecuta un programa. Esto evita que los atacantes puedan predecir direcciones exactas para lanzar ataques de desbordamiento de búfer o inyección de código, haciendo que los intentos de explotación sean extremadamente difíciles de automatizar.

24. Solicitud de falsificación de sitios cruzados (XSRF):

Es un ataque que engaña a un usuario autenticado para que realice acciones no deseadas en una aplicación web (como transferir fondos o cambiar contraseñas) sin su consentimiento. El atacante aprovecha la sesión activa del usuario para "falsificar" una petición legítima. Si la víctima tiene privilegios de administrador, este ataque puede comprometer la totalidad del servidor o la aplicación.

25. Web Tracking:

El seguimiento de sitios web, o seguimiento web, se refiere a la práctica de recopilar y analizar datos sobre la actividad en línea de un usuario. Esto suele hacerlo por sitios web y entidades externas para entender el comportamiento de los usuarios, personalizar contenido, mostrar anuncios dirigidos o mejorar la experiencia del usuario.

El seguimiento puede implicar recopilar diversos tipos de información, como historial de navegación, consultas de búsqueda, datos de ubicación, información del dispositivo e incluso la cantidad de tiempo que se pasa en una página. Aunque algunos seguimientos ayudan a mejorar la funcionalidad del sitio web, como recordar los datos de acceso, otros plantean importantes preocupaciones sobre la privacidad.

26. Web proxy:

Un proxy web es un tipo de servidor proxy es como un intermediario digital entre los usuarios y el internet que, en seguridad de la información, actúa como una puerta de enlace controlada para inspeccionar tráfico, ocultar direcciones IP internas, filtrar contenido malicioso o no deseado, y prevenir ataques directos, mejorando la seguridad perimetral, en resumen este recibe la petición, oculta la identidad (cambia la IP), filtra el contenido por seguridad, entrega la respuesta (usando caché para ir más rápido).

27. Cifrado de Scripts:

En términos aún más simples, el cifrado es una forma de hacer que los datos sean ilegibles para una parte no autorizada. Esto sirve para frustrar a los cibercriminales, osea que enmascarar información confidencial de usuarios no autorizados, el cifrado funciona mediante el uso de algoritmos de cifrado para codificar los datos en un formato indescifrable. Solo las partes autorizadas con la clave secreta correcta, conocida como clave de descifrado, pueden descifrar los datos.

28. Zero Day:

Un exploit de día cero es un vector de ataque cibernético que usa una falla de seguridad desconocida o no abordada en software, hardware o firmware de computadora osea que aprovecha una debilidad oculta incluso para los creadores de algún programa. “Día cero” se refiere al hecho de que el proveedor de software o dispositivo tiene cero días para arreglar la falla porque los actores maliciosos ya pueden usarlo para acceder a sistemas vulnerables.

29. Token:

Es un dispositivo periférico, puede ser físico o digital que se utiliza para obtener acceso a un recurso restringido electrónicamente. El token se utiliza además de, o en lugar de, una contraseña. Algunos ejemplos de tokens de seguridad incluyen tarjetas de acceso inalámbricas que en sí actúa como un sustituto de seguridad de credenciales.

30. Sniffer:

Un sniffer es un programa que monitoriza la información que circula por la red con el objeto de capturar información. Las tarjetas de red pueden verificar si la información recibida está dirigida o no a su sistema. Si no es así, la rechaza.

Un sniffer lo que hace es colocar a la placa de red en un modo el cual desactiva el filtro de verificación de direcciones (promiscuo) y por lo tanto acepta todos los paquetes que llegan a la tarjeta de red del ordenador donde está instalado estén dirigidos o no a ese dispositivo.

El tráfico que no viaje cifrado podrá por tanto ser «escuchado» por el usuario del sniffer. El análisis de tráfico puede ser utilizado también para determinar relaciones entre varios usuarios (conocer con qué usuarios o sistemas se relaciona alguien en concreto).